

Security risk assessment report

Part 1: Select up to three hardening tools and methods to implement

Implementing MFA, stronger password policies and enhancing firewalls

MFA requires users to log in using more than one way to authenticate when logging into an account in order to make it harder for a malicious actor to gain access– for example, pin number, fingerprints, SMS, IDs, etc.

Stronger password and account policies like longer passwords, requiring numbers and symbols, and strongly forbid account and password sharing.

Carry out firewall audits, use risk assessments, incident reports, pen testing, etc. to enhance the protection of the firewalls.

Part 2: Explain your recommendations

Everyone in the company must have their own account so their activity can be monitored with their own passwords for which password rules should be implemented. Passwords must be unique, follow password rules like containing symbols, be longer in length, and avoid the encouragement of frequent changes unless specifically needed, as users will start creating more predictable passwords. Using MFA would also increase security and discourage password sharing between colleagues as everyone would have to identify themselves in more than one way. Account policies like locking an account after a certain amount of failed login attempts should be added to avoid the risk of brute force attacks, and logins at suspicious hours or geo locations should be checked.

Firewalls should not have basic configurations as they are not fit for all different organizations. The process of scoping must be done to customize security controls.

The organization can choose between a stateless, stateful or NGFW firewall to

inspect and limit suspicious traffic - stateful and NGFW walls being the best choices as they are more thorough and work with context and past traffic, with NGFW being the most advanced. Firewall checks should be also done regularly to check if all the rules implemented work well. I would also add that the admin password must be changed to a complex password with limit to failed login attempts and only being known by the admin staff, least privilege could be implemented.